Activity Flowchart - Complete User Journey

This diagram shows the **decision-making flow** and different paths for Customer, Employee, and Admin users.

Mermaid Diagram (Copy this to render)

```
flowchart TD
    Start([User Visits Website]) --> CheckSession{Has Valid
Session Cookie?}

    %% Not Logged In
    CheckSession -->|No| LoginPage[Show Login Page]
    LoginPage --> InputMethod{Input Method}
    InputMethod -->|Manual Login| EnterCreds[Enter Username & Password]
    InputMethod -->|Google OAuth| GoogleAuth[Authenticate with Google]

    EnterCreds --> SubmitLogin[Submit Login Form]
    GoogleAuth --> OAuth[Google OAuth Callback]
    OAuth --> CreateSession

    SubmitLogin --> RateLimit{Rate Limit
Exceeded?}
    RateLimit -->|Yes| ShowError[Show: Too many attempts]
    ShowError --> LoginPage

    RateLimit -->|No| AccountLocked{Account
Locked?}
    AccountLocked -->|Yes - 5 failures| ShowLockout[Show: Account locked for
15min]
    ShowLockout --> LoginPage

    AccountLocked -->|No| ValidateCreds{Credentials
Valid?}
    ValidateCreds -->|No| RecordFailure[Record Failed Attempt]
    RecordFailure --> LoginPage

    ValidateCreds -->|Yes| MFAEnabled{MFA
Enabled?}
    MFAEnabled -->|Yes| EnterMFA[Enter MFA Token]
    EnterMFA --> ValidateMFA{MFA Token
Valid?}
    ValidateMFA -->|No| LoginPage
    ValidateMFA -->|Yes| CreateSession

    MFAEnabled -->|No| CreateSession[Create Session Token]
    CreateSession --> LogSuccess[Log: login_success]
    LogSuccess --> CheckRole{User Role?}

    %% Already Logged In
    CheckSession -->|Yes| ValidateSession{Session
```

```
Expired?}
    ValidateSession -->|Yes - Timeout| LoginPage
    ValidateSession -->|No| CheckRole

    %% Role-Based Routing
    CheckRole -->|Admin| AdminDash[Admin Dashboard]
    CheckRole -->|Employee| EmpDash[Employee Dashboard]
    CheckRole -->|Customer| CustomerDash[Customer Dashboard]

    %% Admin Features
    AdminDash --> AdminAction{Admin Action}
    AdminAction -->|Manage Users| ManageUsers[View/Edit/Delete Users]
    AdminAction -->|View Analytics| ViewAnalytics[View System Analytics]
    AdminAction -->|Manage Knowledge| UploadDocs[Upload Knowledge Base Files]
    AdminAction -->|View Tickets| ViewAllTickets[View All Support Tickets]
    AdminAction -->|Audit Logs| ViewAudit[View Security Logs]

    UploadDocs --> ValidateFile{File Valid?
Size < 10MB
Type in whitelist}
    ValidateFile -->|No| FileError[Show: Invalid file]
    ValidateFile -->|Yes| SaveFile[Save to backend/assets/]
    SaveFile --> IndexKB[Index in Vector Database]

    %% Employee Features
    EmpDash --> EmpAction{Employee Action}
    EmpAction -->|View Customers| ViewCustomers[View Customer List]
    EmpAction -->|Manage Tickets| ManageTickets[Respond to Tickets]
    EmpAction -->|Add Notes| AddNotes[Add Customer Notes]

    ManageTickets --> AssignTicket[Assign Ticket to Self]
    AssignTicket --> RespondTicket[Add Response]
    RespondTicket --> UpdateStatus[Update Ticket Status]
    UpdateStatus --> NotifyCustomer[Create Notification]

    %% Customer Features
    CustomerDash --> CustAction{Customer Action}
    CustAction -->|Create Ticket| CreateTicket[Fill Ticket Form]
    CustAction -->|View My Tickets| ViewMyTickets[View Ticket History]
    CustAction -->|Ask AI Question| AskAI[Use Voice/Text Chat]
    CustAction -->|Give Feedback| SubmitFeedback[Thumbs Up/Down]

    CreateTicket --> ValidateTicket{CSRF Token
Valid?}
    ValidateTicket -->|No| CSRFError[Show: Security error]
    ValidateTicket -->|Yes| SaveTicket[Save to Database]
    SaveTicket --> GenTicketNum[Generate: TKT-YYYYMMDD-XXXX]
    GenTicketNum --> NotifyEmployee[Notify Employees]

    AskAI --> RAGPipeline[RAG Server: /ws]
    RAGPipeline --> WSRateLimit{WebSocket
Rate Limit?
20 msg/min}
    WSRateLimit -->|Exceeded| WSError[Show: Slow down]
```

```
    WSRateLimit -->|OK| EmbedQuery[Embed User Query]
    EmbedQuery --> SearchVector[Search Vector Database]
    SearchVector --> RetrieveDocs[Retrieve Relevant Chunks]
    RetrieveDocs --> AugmentPrompt[Augment Prompt with Context]
    AugmentPrompt --> CallLLM[Call LLM with RAG Context]
    CallLLM --> GenerateResponse[Generate Response]
    GenerateResponse --> ReturnResponse[Return Text/Voice Response]

    %% Common Actions
    ManageUsers --> LogAction[Log Security Event]
    ViewAnalytics --> LogAction
    ViewAllTickets --> LogAction
    NotifyEmployee --> LogAction
    LogAction --> Dashboard

    ReturnResponse --> Dashboard
    CSRFError --> Dashboard
    FileError --> Dashboard
    NotifyCustomer --> Dashboard

    %% Logout
    AdminDash --> Logout{Logout?}
    EmpDash --> Logout
    CustomerDash --> Logout
    Logout -->|Yes| InvalidateSession[Invalidate Session Token]
    InvalidateSession --> DeleteCookie[Delete SESSION_COOKIE]
    DeleteCookie --> LogLogout[Log: logout event]
    LogLogout --> LoginPage
    Logout -->|No| Dashboard[Stay on Dashboard]

    Dashboard --> End([Session Active])
```

How to Use This Diagram:

Same as Sequence Diagram:

1. Install **Markdown Preview Mermaid Support** in VS Code
2. Press `Ctrl+Shift+V` to preview
3. Or paste at https://mermaid.live/

Decision Points Explained:

Decision	What It Checks
Has Valid Session Cookie?	Checks if user is already logged in
Rate Limit Exceeded?	Max 5 login attempts per minute per IP
Account Locked?	5 failed attempts = 15min lockout
Credentials Valid?	bcrypt_sha256 password verification
MFA Enabled?	User has 2FA turned on

Decision	What It Checks
Session Expired?	24h absolute OR 30min idle timeout
User Role?	Admin, Employee, or Customer
CSRF Token Valid?	Prevents cross-site request forgery
File Valid?	Max 10MB, allowed extensions only
WebSocket Rate Limit?	Max 20 messages per minute

User Flows:

Customer Flow:

1. Login → Customer Dashboard → Create Ticket → Get Help from AI → Logout

Employee Flow:

1. Login → Employee Dashboard → View Tickets → Respond to Ticket → Add Customer Notes

Admin Flow:

1. Login → Admin Dashboard → Manage Users → Upload Knowledge Base → View Analytics

Security Features Shown:

- ☑ Rate limiting (login, WebSocket)
- ☑ Account lockout (brute force protection)
- ☑ Session validation (timeout checks)
- ☑ CSRF protection (ticket creation)
- ☑ File upload validation (size, type)
- ☑ Role-based access control (RBAC)
- ☑ Security logging (all actions tracked)